

I. Disposiciones generales

Consejería de Sanidad

1709 *ORDEN de 14 de mayo de 2026, por la que se aprueba la política de seguridad de la información del Servicio Canario de la Salud.*

PREÁMBULO

El Servicio Canario de la Salud cuenta con una Política de Seguridad de la Información (PSI) aprobada por Resolución de la Dirección del Servicio Canario de la Salud, el 5 de febrero de 2014 (BOC n.º 30, de 13.2.2014). A pesar de la adaptación constante, se ha dictado normativa que es necesario contemplar expresamente en la documentación de la PSI al más alto nivel.

Por una parte, la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, en su artículo 3, establece que las Administraciones Públicas han de asegurar en sus relaciones a través de medios electrónicos la interoperabilidad y seguridad de los sistemas. También el artículo 13 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, recoge el derecho de las personas en sus relaciones con las Administraciones Públicas a la protección de datos personales, a la seguridad y confidencialidad de los datos que figuren en los ficheros, sistemas y aplicaciones.

Por otra parte, la normativa de protección de datos personales contenida en Reglamento (UE) 2016/679, del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (RGPD), y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, cuya disposición adicional primera establece que en los tratamientos de datos personales realizados en el ámbito del sector público se deben aplicar las medidas de seguridad que correspondan de las previstas en el Esquema Nacional de Seguridad (ENS).

El Real Decreto 311/2022, de 3 de mayo, que regula el Esquema Nacional de Seguridad, establece, en el artículo 12, que la Política de Seguridad de la Información es el conjunto de directrices que rigen la forma en que una organización gestiona y protege la información que trata y los servicios que presta. Cada órgano o entidad con personalidad jurídica propia del sector público deberá contar con una Política de Seguridad formalmente aprobada por el órgano competente.

El Servicio Canario de la Salud, organismo autónomo creado por Ley 11/1994, de 26 de julio, de Ordenación Sanitaria de Canarias, se enfrenta a retos crecientes de transformación digital en la forma en que se gestionan los recursos tecnológicos y clínicos. En un entorno cada vez más digitalizado, el sistema sanitario se ha convertido en un objetivo prioritario para amenazas que comprometen la seguridad de la información, la continuidad operativa de los servicios y, en última instancia, la seguridad del paciente.

El objetivo de la seguridad de la información es asegurar el acceso, la confidencialidad, la integridad, la trazabilidad, la autenticidad, la disponibilidad y la conservación de los datos, la información y los servicios utilizados por medios electrónicos en el ejercicio de

sus competencias. Actuar proactiva y preventivamente, realizar un monitoreo constante del rendimiento de los servicios, analizar vulnerabilidades reportadas y establecer una respuesta rápida y eficaz frente a ciberincidentes, garantizando de esta manera la continuidad operativa. Esto implica que el Servicio Canario de la Salud debe aplicar las medidas mínimas de seguridad exigidas por el ENS a todos los niveles desde el estratégico hasta los niveles tácticos y operativos, incluyendo la interacción directa con la cadena de suministro y los proveedores implicados.

La Directiva Europea sobre Seguridad de las Redes y los Sistemas Informáticos (NIS2) clasifica al sector salud como de alta criticidad, lo que impone una serie de obligaciones en materia de ciberseguridad. El uso de la Inteligencia Artificial y la implantación del Espacio Europeo de Datos de Salud supone un nuevo paradigma y desafíos en el uso y seguridad de los datos de los servicios de salud. La creciente dependencia de las tecnologías de la información, la sensibilidad de los datos clínicos y la complejidad de los sistemas implicados hacen imprescindible aplicar estrategias de ciberseguridad de ámbito nacional, en el Sistema Nacional de Salud y en el ámbito concreto del Servicio Canario de la Salud y así se recoge en el Plan de Salud de Canarias 2026-2031.

Para la elaboración de la PSI se han tomado como referentes las Guías de Seguridad emitidas por el Centro Criptológico Nacional, entre ellas la CCN-STIC-801 ENS. Responsabilidades y Funciones, la CCN-STIC-805, ENS. Política de Seguridad y la CCN-STIC-891, Perfil de Cumplimiento Específico para Salud.

En la tramitación de esta Orden se ha dado cumplimiento a los principios de buena regulación a los que se refiere el artículo 129.1 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, y el artículo 66 de la Ley 4/2023, de 23 de marzo, de la Presidencia y del Gobierno de Canarias. Se han aplicado los principios de necesidad, eficacia y eficiencia, en tanto que da cumplimiento a la obligación que viene impuesta por la normativa referenciada en materia de seguridad de la información y protección de datos personales mediante un instrumento conjunto que resulta el más adecuado para su consecución, abarcando ambas materias dada la íntima conexión entre ellas en el ámbito de competencias del Servicio Canario de la Salud, con la consecuente racionalización de su aplicación.

En cumplimiento del principio de responsabilidad, se establecen y definen los distintos roles para hacer efectiva la seguridad de la información y la protección de los datos personales.

Cumple con el principio de proporcionalidad al no ser restrictiva de derechos y mantener un equilibrio entre los impactos previsibles de la norma y las medidas que se adoptan para conseguir establecer las condiciones de confianza necesarias en el uso de los medios electrónicos, mediante la aplicación de las medidas que garanticen la seguridad de los sistemas, las comunicaciones, los servicios electrónicos y el cumplimiento de las obligaciones establecidas en la normativa vigente en materia de protección de datos personales.

Respeto la seguridad jurídica, al ser coherente con el resto del ordenamiento jurídico autonómico, nacional y de la Unión Europea, generando un marco regulatorio que define el ámbito de aplicación, el marco organizativo y los instrumentos para desarrollar

su contenido. Satisface el principio de accesibilidad mediante el uso de una redacción sencilla e inteligible, pero a su vez rigurosa. Y facilitando su conocimiento por parte de los destinatarios mediante su publicación en el Boletín Oficial de Canarias y sede electrónica, conforme al principio de transparencia.

Por otro lado, la norma respeta el principio de igualdad y el enfoque de género en relación con la utilización de un lenguaje no sexista, de conformidad con la Ley Orgánica 3/2007, de 22 de marzo, para la igualdad efectiva de mujeres y hombres, y con la Ley 1/2010, de 26 de febrero, Canaria de Igualdad entre Mujeres y Hombres.

En el procedimiento de elaboración de la presente Orden se ha prescindido de los trámites previstos en los apartados 1 y 2 del artículo 133 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, al amparo de lo dispuesto en el apartado 4 del mismo precepto, al tratarse de una norma de carácter organizativo.

En virtud de lo expuesto, visto el informe de la Dirección General de Transformación Digital de los Servicios Públicos, en el ejercicio de las competencias conferidas por el artículo 2.2 de la Orden de 31 de julio de 2013, de la Consejería de Presidencia, Justicia e Igualdad, que establece el marco común y las directrices básicas de la política de seguridad de la información en el ámbito de la Administración electrónica de la Administración Pública de la Comunidad Autónoma de Canarias, y haciendo uso de las facultades conferidas en los artículos 58.1, letra b), y 76.3 de la Ley 4/2023, de 23 de marzo, de la Presidencia y del Gobierno de Canarias, en relación con lo dispuesto en el artículo 5 del Decreto 5/2016, de 15 de febrero, por el que se aprueba el Reglamento Orgánico de Sanidad,

DISPONGO:

Único.- Política de seguridad de la información.

Aprobar la política de seguridad de la información del Servicio Canario de la Salud (PSI) que se incorpora como anexo a la presente Orden.

Disposición adicional primera.- Definiciones.

Las expresiones y términos utilizados en esta Orden y en la PSI que se aprueba por la misma, han de entenderse con el significado indicado en el glosario de términos incluido en el Anexo IV del Real Decreto 311/2022, de 3 de mayo, por el que se aprueba el ENS así como en las definiciones del artículo 4 del Reglamento General de Protección de Datos.

Disposición adicional segunda.- Marco normativo.

La presente Orden se entenderá sin perjuicio de lo dispuesto en la normativa nacional o europea en materia de protección de datos personales y aquella que tenga por objeto establecer la política de seguridad en la utilización de medios electrónicos de las Administraciones Públicas o cualesquiera otras disposiciones legales que resulten de aplicación.

Disposición adicional tercera.- Facultad para actualizar la PSI.

Se faculta al titular de la Dirección del Servicio Canario de la Salud para actualizar y desarrollar los aspectos técnicos de la presente PSI, a propuesta del Comité de Coordinación de la Seguridad de la Información y Protección de Datos Personales.

Designación derogatoria única.- Derogación normativa.

Quedan derogadas las normas de igual o inferior rango en lo que contradigan o se opongan a la presente Orden y específicamente la Resolución de la Directora del Servicio Canario de la Salud, el 5 de febrero de 2014, por la que se aprueba la Política de Seguridad.

Disposición final única.- Entrada en vigor.

La presente Orden entrará en vigor a los 20 días de su publicación en el Boletín Oficial de Canarias.

Las Palmas de Gran Canaria, a 14 de mayo de 2026.

LA CONSEJERA
DE SANIDAD,
p.d.f. (Orden n.º 238/2026, de 15 de abril),
la Secretaria General Técnica,
Esther María Monzón Monzón

ANEXO

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN DEL SERVICIO CANARIO DE LA SALUD

1. OBJETO.

1. El presente documento contiene la Política de Seguridad de la Información (PSI) del Servicio Canario de la Salud (SCS) de acuerdo con lo previsto en el artículo 12.3 del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS).

2. La PSI es el conjunto de directrices que rigen la forma en la que el SCS gestiona y protege la información que trata y los servicios que presta, con los con los siguientes objetivos generales:

a) Garantizar la calidad y protección de la información y los servicios, así como el cumplimiento de legislación vigente en materia de seguridad de la información y protección de datos personales.

b) Asegurar la disponibilidad de los servicios, la capacidad de gestión de los incidentes de seguridad actuando preventivamente y la resolución eficaz de los que pudieran surgir,

c) Proteger los activos y recursos de información y tecnología utilizada frente a amenazas internas o externas, garantizando la confidencialidad, integridad, disponibilidad, autenticidad uso previsto y valor de la información y los servicios.

d) Controlar la efectividad de las medidas de seguridad a través de las evaluaciones, auditorías y supervisión continua el sistema de gestión de la seguridad.

e) Promover la cultura de la seguridad a través de la formación y concienciación del personal del respeto a las normas sobre seguridad de la información.

2. MISIÓN.

El Servicio Canario de la Salud es un organismo autónomo de carácter administrativo creado por la Ley 11/1994, de 26 de julio, de Ordenación Sanitaria de Canarias, que busca promover la mejora de la salud de la población a través del desarrollo de las competencias de la Comunidad Autónoma de Canarias en materia de promoción y protección de salud, prevención de la enfermedad, asistencia, cuidado, rehabilitación, la gestión y administración de los centros, servicios y establecimientos sanitarios integrados o adscritos al mismo, así como la formación permanente de los profesionales del ámbito social y sanitario.

3. PRINCIPIOS BÁSICOS DE LA PSI.

La PSI se desarrolla aplicando los siguientes principios básicos:

1. Seguridad integral, entendida como un proceso integral constituido por todos los elementos técnicos, humanos, materiales y organizativos relacionados con el Sistema.

2. Gestión de riesgos, donde el análisis de estos será parte esencial del proceso de seguridad, y cuya gestión dará lugar al mantenimiento de un entorno controlado, minimizando los riesgos hasta niveles aceptables.

3. Prevención, reacción y recuperación ante incidentes, para evitar que las amenazas se materialicen y no afecten gravemente a la información que maneja o a los servicios que se prestan.

4. Líneas de defensa, estableciendo una estrategia de protección constituida por múltiples capas de seguridad.

5. Reevaluación periódica de las medidas de seguridad y actualización permanente de las mismas.

6. Función diferenciada, donde la responsabilidad de la seguridad TIC estará diferenciada de la responsabilidad del sistema y, por tanto, de la responsabilidad sobre la prestación de los servicios.

4. ALCANCE.

1. La PSI se aplicará a todos los sistemas de información que den soporten los servicios del SCS.

2. La PSI se aplicará a todas las personas que intervengan en la prestación de los servicios del SCS y hagan uso de los sistemas de información y recursos TIC del SCS, independientemente de que sean personal del SCS o externo, empleados públicos o no, sea mediante conexión directa o indirecta a los mimos, conexión remota o a través de equipos ajenos al SCS, incluyendo los servicios prestados a través de internet.

3. La PSI será de aplicación al tratamiento de datos personales de los que es responsable el SCS.

5. MARCO NORMATIVO.

Las referencias normativas tenidas en cuenta para la redacción de esta Política:

- Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (LPAC).

- Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

- Real Decreto 203/2021, de 30 de marzo, por el que se aprueba el Reglamento de actuación y funcionamiento del sector público por medios electrónicos.

- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS).

- Real Decreto 4/2010, de 8 de enero, por el que se regula el Esquema Nacional de Interoperabilidad en el ámbito de la Administración Electrónica.

- Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

- Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento General de Protección de Datos, RGPD).

- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales.

- Ley 11/1994, de 26 de julio, de Ordenación Sanitaria de Canarias.

- Ley 16/2003, de 23 de mayo, de cohesión y calidad del Sistema Nacional de Salud.

- Ley 41/2002, de 14 de noviembre, básica reguladora de la autonomía del paciente y de derechos y obligaciones en materia de información y documentación clínica.

- Real Decreto 183/2004, de 30 de enero, por el que se regula la tarjeta sanitaria individual.

- Real Decreto 1718/2010, de 17 de diciembre, sobre receta médica y órdenes de dispensación.

- Decreto 32/1995, de 24 de febrero, por el que se aprueba el Reglamento de Organización y Funcionamiento del Servicio Canario de la Salud.

6. ESTRUCTURA ORGANIZATIVA DE LA SEGURIDAD DE LA INFORMACIÓN.

1. La estructura organizativa de la gestión de la seguridad de la información en el ámbito del SCS está compuesta por los siguientes roles:

a) El Comité de Coordinación de Seguridad de la Información y de Protección de Datos Personales del SCS.

b) Responsable de la Información.

c) Responsables de los Servicios.

d) Responsable de la Seguridad.

e) Responsables de la Seguridad Delegados.

f) Comité Ejecutivo de la Seguridad de la Información.

g) Responsable del Sistema.

h) Persona Delegada de Protección de Datos.

2. Los roles de seguridad serán revisados cada cuatro años o con ocasión de su sustitución o vacante.

3. Corresponde a la Dirección del SCS el nombramiento formal de las personas Responsables de la Seguridad y responsable del sistema.

7. COMITÉ DE COORDINACIÓN DE SEGURIDAD DE LA INFORMACIÓN Y DE PROTECCIÓN DE DATOS PERSONALES.

1. El Comité de Coordinación de Seguridad de la Información y de Protección de Datos Personales (COCOSEG) es un órgano colegiado que coordina las actividades y controles de seguridad, velando por el cumplimiento de la normativa vigente (interna y externa).

2. Composición:

- Titular de la Dirección del SCS que ostentará la presidencia.
- Titular de la Secretaría General del SCS que ostentará la vicepresidencia.
- Responsable de la Seguridad.
- Responsables de los Servicios.
- Responsable del Sistema.
- Persona Delegada de Protección de Datos, con voz pero sin voto

3. La Secretaría se ejerce por la persona que designe la Presidencia, y en su defecto, por el Responsable de la Seguridad, o por persona que este designe, la cual actuará con voz y sin voto si no fuera miembro del Comité.

4. El Comité de Coordinación podrá recabar la información y asesoramiento pertinente para el ejercicio de sus funciones del personal técnico necesario, y este personal podrá ser convocado a las reuniones, en calidad de asesores, con voz pero sin voto.

5. El Comité de Coordinación se reunirá con carácter ordinario, al menos, una vez por semestre. Por razones de urgencia podrá reunirse siempre que la Presidencia lo estime conveniente. No se percibirán indemnizaciones en concepto de asistencia por concurrencia al Comité.

6. Podrá acordarse la constitución de subgrupos de trabajo para el análisis, elaboración y ejecución de trabajos o actividades específicas, dentro del ámbito de sus funciones.

7. El Comité de Coordinación desarrollará su Reglamento Interno. En cuanto a su funcionamiento se regirá, en todo lo no previsto en la presente Orden, por lo dispuesto en el título II, sección 3.^a del título preliminar la Ley 40/2015, de RJSP.

8. FUNCIONES DEL COMITÉ DE COORDINACIÓN DE SEGURIDAD DE LA INFORMACIÓN Y DE PROTECCIÓN DE DATOS PERSONALES.

Son funciones del Comité de Coordinación de Seguridad de la Información de Protección de Datos Personales:

1. Revisar regularmente la Política de Seguridad de la Información y proponer sus actualizaciones.

2. Analizar y realizar el seguimiento de los principales riesgos residuales asumidos por la Administración y recomendar posibles actuaciones respecto de ellos.

3. Impulsar medidas para la mejora continua y reforzar el sistema de gestión de la seguridad de la Información.

4. Impulsar el cumplimiento y difusión de la PSI promoviendo actividades destinadas a formar y sensibilizar al personal en materia de seguridad de la información y en particular en materia de protección de datos de carácter personal.

5. Verificar los procedimientos de seguridad de la información y demás documentación.

6. Realizar un seguimiento de la gestión de los incidentes de seguridad y recomendar posibles actuaciones respecto de ellos.

7. Proponer planes de mejora de la seguridad de la información priorizando las actuaciones en materia de seguridad.

8. Promover la realización de auditorías que permitan verificar el cumplimiento de las obligaciones del SCS en materia de seguridad de la Información.

9. Velar porque se respete el principio de seguridad desde el diseño en todas aquellas iniciativas que afecten a la seguridad de la información o de los sistemas. En particular, deberá velar por la creación y utilización de servicios horizontales que reduzcan duplicidades y apoyen un funcionamiento homogéneo de todos los sistemas en el ámbito de aplicación del ENS.

10. Coordinar los esfuerzos de las diferentes áreas en materia de seguridad de la información, para asegurar que estos sean consistentes, alineados con la estrategia decidida en la materia, y evitar duplicidades.

11. Velar porque la seguridad de la información se tenga en cuenta en todos los proyectos desde su especificación inicial hasta su puesta en operación. En particular deberá velar por la creación y utilización de servicios horizontales que reduzcan duplicidades y apoyen un funcionamiento homogéneo de todos los sistemas TIC.

12. Asesorar en la resolución de los conflictos de responsabilidad que puedan aparecer entre los diferentes roles.

9. RESPONSABLE DE LA INFORMACIÓN.

1. Responsable de la Información es la persona que determina los requisitos de seguridad de la información bajo su responsabilidad.

2. Son funciones del Responsable de Información las siguientes:

a) Determinar los criterios para asignar y modificar a cada información el nivel de seguridad requerido y será responsable de su documentación y aprobación formal.

b) Determinar los niveles de seguridad de la información, valorando los impactos de los incidentes que afectan a la seguridad de la información así como, en su caso, su posterior modificación.

c) Es el responsable, junto a los Responsables del Servicio, de aceptar los riesgos residuales calculados en el análisis de riesgos, y de realizar su seguimiento y control.

d) Con el asesoramiento de DPD, asegurarse de que a la información que contenga datos de carácter personal se le aplica las medidas de seguridad exigidas por la legislación vigente en la materia.

e) Cualquier otra función que se entienda pertinente en el ámbito de las funciones generales que le corresponden en materia de seguridad de la información.

3. El Responsable de la Información es la persona titular de la Dirección del SCS.

10. RESPONSABLES DE LOS SERVICIOS.

1. Los Responsables de los Servicios son las personas u órganos que determinan los requisitos de seguridad de los servicios prestados.

2. Respecto de los servicios de los que sean responsables, sus funciones son:

a) Determinar los niveles de seguridad de los servicios, valorando los impactos de los incidentes que afecten a la seguridad de la información, así como, en su caso, su posterior modificación.

b) Respecto al proceso de gestión del riesgo, los Responsables de los Servicios son los encargados, junto al Responsable de la Información, de aceptar los riesgos residuales calculados en el análisis, y de realizar su seguimiento y control.

c) Cualquier otra función que se entienda pertinente en el ámbito de las funciones generales que les corresponden en materia de seguridad de la información.

3. Son Responsables de los Servicios, en su ámbito de competencias, las personas titulares de las Direcciones Generales, Direcciones de Áreas, Gerencias de Atención Primaria, Gerencias de Servicios Sanitarios y Direcciones-Gerencias hospitalarias.

11. RESPONSABLE DE LA SEGURIDAD DEL SCS.

1. El Responsable de la Seguridad es la persona que determina las decisiones para satisfacer los requisitos de seguridad de la información y de los servicios, supervisará la implantación de las medidas necesarias para garantizar que se satisfacen los requisitos y reportará sobre estas cuestiones.

2. Todos los implicados en el proceso de seguridad actuarán de forma coordinada en la aplicación y control de las medidas de seguridad conforme determine la persona Responsable de la Seguridad.

3. El Responsable de la Seguridad dirige el Comité Ejecutivo de Seguridad y las Oficinas Técnicas que puedan crearse o desplegarse, con personal propio o externo, para el apoyo a las funciones del Responsable de la Seguridad.

4. El Responsable de la Seguridad es la persona titular de la Subdirección de Seguridad de la Información del SCS.

12. FUNCIONES DEL RESPONSABLE DE LA SEGURIDAD.

Son funciones del Responsable de la Seguridad:

1. Determinar las medidas de seguridad necesarias, incluidas medidas adicionales, para cumplir con los requisitos de seguridad de la información y de los servicios prestados, en función de las valoraciones hechas por los responsables de la Información y los Servicios.
2. Participar en la elaboración y en la propuesta de la Política de Seguridad de la Información y los procedimientos, normativas e instrucciones en aplicación del ENS.
3. Comprobar que las medidas de seguridad de la información han sido adecuadamente implementadas por el Responsable del Sistema.
4. Realizar los preceptivos análisis de riesgos, seleccionar las salvaguardas a implantar y revisar el proceso de gestión del riesgo.
5. Encargarse de que la documentación de seguridad se mantenga organizada y actualizada, y de gestionar los mecanismos de acceso a la misma.
6. Promover la concienciación y formación en materia de seguridad en su ámbito de responsabilidad.
7. Gestionar el proceso de certificación al ENS y demás certificaciones exigibles.
8. Promover auditorías periódicas para verificar el cumplimiento de las obligaciones en materia de seguridad de la información, y analizar los informes de auditoría, elaborando las conclusiones a presentar a los Responsables del Servicio y al Responsable de la Información para que adopten las medidas correctoras adecuadas.
9. Coordinar el proceso de Gestión de la Seguridad.
10. Elaborar y aprobar la Declaración de Aplicabilidad, atendiendo a los requerimientos del Responsable de la Información y del Servicio.
11. Determinar la categoría del sistema y realizar las evaluaciones según el procedimiento descrito en el Anexo I del Real Decreto 311/2022, de 3 de mayo, por el que se regula el ENS.
12. Promover y garantizar la existencia de un procedimiento de notificación, gestión y registro de los incidentes de seguridad, así como analizar el contenido de dicho registro para adoptar, si proceden, medidas de seguridad de carácter preventivo y/o correctivo.
13. Participar en la elaboración e implantación de los planes de mejora de la seguridad y, llegado el caso, en los planes de continuidad, procediendo a su validación.
14. Elaborar informes periódicos de seguridad para el Comité de Coordinación que incluyan los incidentes más relevantes, e informar inmediatamente de los incidentes de carácter grave.

15. Analizar los riesgos antes del despliegue de los sistemas de inteligencia artificial en la entidad, atendiendo a las valoraciones del Responsable de la Información y del Servicio y, en su caso, del DPD y supervisar su despliegue.

16. Recoger los requisitos de protección de datos personales que sean fijados por el responsable o encargado del tratamiento, contando con el asesoramiento del DPD, y que sean necesarios implementar en los sistemas de acuerdo a la naturaleza, alcance, contexto y fines del mismo, así como de los riesgos para los derechos y libertades de acuerdo a lo establecido en los artículos 24 y 32 del RGPD, y con la evaluación de impacto en la protección de datos.

17. Coordinar con el CSIRT y/o la Autoridad de Control correspondiente, cualquier incidente que tenga un impacto significativo en la prestación de sus servicios. En su caso, notificar a las personas destinatarios de los servicios sanitarios, información relacionada con el incidente, las medidas o soluciones frente a la ciberamenaza.

18. Calificará la peligrosidad de los ciberincidentes de acuerdo a la Guía CCN-STIC 817.

19. Cualquier otra función que se entienda pertinente en el ámbito de las funciones generales que le corresponden en materia de seguridad de la información.

13. RESPONSABLES DE LA SEGURIDAD DELEGADOS.

1. El Responsable de la Seguridad designará Responsables de la Seguridad delegados para el ámbito de uno o varios órganos del SCS o para materias transversales concretas, previa comunicación al titular del órgano de que dependa.

2. Cada Responsable de la Seguridad Delegado mantendrá una dependencia funcional directa de la persona Responsable de la Seguridad del SCS, a quien reportará, siguiendo sus directrices.

3. Al Responsable de la Seguridad Delegado le corresponden las siguientes funciones:

a) Identificar los sistemas de información de su centro, mantener el inventario actualizado de los mismos y categorizarlos.

b) Ser el punto de contacto con Responsable de la Seguridad y DPD para cualquier actuación en el ámbito de la seguridad de la información y protección de datos.

c) Coordinar y mantener la seguridad de la información dentro de su ámbito.

d) Aplicar la normativa de seguridad transversal y específica de su ámbito, debiendo notificar periódicamente al Responsable de la Seguridad sobre la actividad desarrollada dentro de su ámbito y los riesgos a los que están expuestos, y cuando las circunstancias lo requieran.

e) Notificar al Responsable de la Seguridad la adquisición o implantación de nuevos productos y servicios conforme a las indicaciones que establezca.

f) Atender los requerimientos del Responsable de la Seguridad dentro del plazo indicado, notificando al titular del centro directivo del que dependa cuando las circunstancias lo requieran.

g) Promover la concienciación y formación dentro de su ámbito, de acuerdo con los planes de formación corporativos. Detectar y recibir las necesidades formativas.

h) Apoyar en la gestión de incidentes de seguridad.

i) Analizar los riesgos a los que los sistemas de información estén expuestos, formalizar y firmar la “Declaración de Aplicabilidad” relativa a los sistemas propios.

j) Colaborar en tareas de inspección mediante la realización de auditorías y controles periódicos. Analizar los informes de auditoría.

k) Realización de análisis de riesgos

l) Recabar la información necesaria de las unidades correspondientes, para certificar el cumplimiento de medidas de seguridad gestionadas por otros.

m) Aquellas otras funciones que se establezcan por delegación.

14. COMITÉ EJECUTIVO DE SEGURIDAD DE LA INFORMACIÓN.

1. El Comité Ejecutivo de Seguridad de la Información (CESI) se integra por el Responsable de la Seguridad y Responsables de la Seguridad Delegados y tiene por finalidad asegurar el carácter transversal de la seguridad de la información del SCS en la implantación efectiva de las funciones que corresponden al Responsable de la Seguridad SCS.

2. El Comité Ejecutivo de Seguridad será convocado y presidido por el Responsable de la Seguridad, que designará la secretaría del mismo.

3. El Comité Ejecutivo de Seguridad ejercerá las siguientes funciones:

a) Coordinar la implantación de las medidas de seguridad adoptadas.

b) Participar en la categorización de los sistemas de información en función de las valoraciones realizadas por los responsables de la información y colaborar en seleccionar medidas de seguridad apropiadas.

c) Promover y difundir normas, procedimientos e instrucciones técnicas.

d) Proponer programas de concienciación y formación en seguridad de la información y protección de datos para ser aprobados.

e) Proponer y elaborar, junto con la persona responsable del sistema, los planes de mejora de seguridad de los sistemas de información.

f) Proponer y elaborar los Planes de Continuidad del Negocio.

g) Proponer Planes de Auditoria.

h) Proponer medidas correctivas y mejoras, derivadas de las auditorías de seguridad de la información y protección de datos personales, análisis de riesgos y evaluaciones de impacto, así como hacer el seguimiento de su implantación.

15. RESPONSABLE DEL SISTEMA.

1. El Responsable del Sistema es el responsable de aplicar las medidas de seguridad de índole tecnológica determinadas por el Responsable de la Seguridad.

2. Son funciones del Responsable del Sistema las siguientes:

a) Desarrollar, operar y mantener el sistema de información durante todo su ciclo de vida, de sus especificaciones, instalación y verificación de su correcto funcionamiento.

b) Implantar y mantener las medidas de seguridad aplicables a los sistemas de información, conforme al ENS y demás normativa de ciberseguridad aplicable, del servicio durante todo su ciclo de vida, siguiendo las indicaciones del Responsable de la Seguridad.

c) Aprobar toda modificación sustancial de la configuración de cualquier elemento del sistema.

d) Analizar las conclusiones elevadas por el Responsable de la Seguridad de las auditorías, revisiones internas y autoevaluaciones realizada y proponer medidas.

e) Detener el acceso a información o la prestación de un servicio electrónico si es informado de deficiencias graves de seguridad.

f) Definir la topología y sistema de gestión del sistema de información, estableciendo los criterios de uso y los servicios disponibles en el mismo.

g) Adoptar las medidas correctoras adecuadas que garanticen la seguridad de los sistemas de información.

h) Registrar, gestionar, notificar y solucionar incidencias, en colaboración con la persona Responsable de la Seguridad y Responsables de la Seguridad Delegados.

i) Elaborar informes respecto a las actuaciones realizadas en su ámbito de responsabilidad, con la periodicidad que se establezca.

j) Colaborar, reportar y atender los requerimientos de información de la persona Responsable de la Seguridad.

k) Colaborar en las auditorías de seguridad y en la gestión de riesgos.

l) Designar y formalizar nombramientos de los responsables de sistemas delegados que considere necesarios.

m) Cualquier otra función que se entienda pertinente en el ámbito de las funciones generales que les corresponden, en materia de seguridad de la información.

3. Responsable del Sistema será la persona titular del Área de Sistemas Electromédicos y de la Información (ASEI).

16. PERSONA DELEGADA DE PROTECCIÓN DE DATOS.

1. La persona delegada de protección de datos personales (DPD) asesora y supervisa el cumplimiento de la normativa de protección de datos personales asumiendo las funciones establecidas en el artículo 39 RGPD y resto de articulado, normativa estatal y autonómica.

2. El DPD ejercerá, de manera independiente, las siguientes funciones:

a) Promover el cumplimiento de la normativa vigente en materia de protección de datos personales y asesorar en el desarrollo, actualización y mejora continua del marco normativo interno del SCS en esta materia.

b) Supervisar las actuaciones de protección de datos, incluyendo su implementación, desde el diseño y por defecto, la asignación de responsabilidades y que se realizan las auditorías correspondientes.

c) Promover la concienciación y la formación del personal que participa en las operaciones de tratamiento de datos personales y asesorar al responsable del tratamiento en caso de reclamación de los afectados ante la autoridad de control.

d) Constituir grupos de trabajo en materia de protección de datos para promover buenas prácticas compartidas.

e) Informar y asesorar a las unidades en la realización de análisis de riesgos, evaluaciones de impacto, auditorías y controles periódicos, para verificar el cumplimiento de las obligaciones en materia de protección de datos personales.

f) Informar regularmente a la persona titular del SCS acerca del cumplimiento de la normativa de protección de datos personales.

g) Cooperar con las autoridades de control y actuar como interlocutor del responsable del tratamiento ante las mismas, así como trasladar las notificaciones de brechas de seguridad en materia de protección de datos a la autoridad de control y a los interesados cuando proceda.

3. El DPD contará con soporte administrativo y técnico competente en materia de seguridad de la información y protección de datos dirigiendo los recursos puestos a su disposición en lo que respecta al contenido de sus funciones.

4. En el desempeño de sus funciones, el DPD tendrá acceso a los datos personales y operaciones de tratamiento.

17. GRUPOS DE TRABAJO.

Los responsables podrán designar delegados que considere necesarios, que tendrán dependencia funcional directa de aquel y serán responsables en su ámbito de todas aquellas acciones que se les deleguen.

18. RESOLUCIÓN DE CONFLICTOS.

En caso de conflicto entre los diferentes responsables que componen la estructura organizativa de la Política de Seguridad de la Información, este será resuelto por el superior jerárquico de los mismos, previa consulta al COCOSEG.

En caso de conflictos entre los responsables que componen la estructura organizativa de la Política de Seguridad de la Información y los definidos en seguimiento de la normativa de protección de datos de carácter personal, prevalecerá la decisión que presente un mayor nivel de exigencia respecto a la protección de los datos de carácter personal.

19. ESTRUCTURA DOCUMENTAL Y NORMATIVA.

El cuerpo normativo en materia de seguridad dentro del SCS se desarrollará en tres niveles, según el ámbito de aplicación y nivel de detalle técnico, de manera que cada norma de un determinado nivel de desarrollo se fundamente en las normas de nivel superior. Dichos niveles de desarrollo normativo son los siguientes:

- a) Primer nivel normativo: la propia Política de Seguridad de la Información (PSI).
- b) Segundo nivel normativo: Normas Generales de Seguridad que emanan de la PSI y soportan los diferentes ámbitos de seguridad sin entrar en detalles de implementación ni tecnológicos.
- c) Esta normativa la aprueba el Comité Coordinación de Seguridad de la Información y Protección de Datos y deberán adoptarse por Resolución de la persona titular de la Dirección del SCS.
- d) Tercer nivel normativo: Procedimientos Generales, procedimientos donde se incluyan detalles de implementación y tecnológicos sobre cómo se puede realizar una determinada tarea considerada crítica por el perjuicio que causaría una actuación inadecuada de seguridad, de desarrollo, de mantenimiento y de explotación de los sistemas de información. Serán aprobados por el Responsable de la Seguridad o el Responsable del Sistema, según su ámbito de actuación.
- e) Cuarto nivel: Guías y Manuales Generales proporcionan pasos a seguir para la correcta implantación de las medidas de seguridad. Además, la estructura documental podrá incluir otros documentos como recomendaciones, buenas prácticas, informes, registros, evidencias electrónicas, conclusiones de un estudio o una evaluación.

Serán aprobados por los roles definidos en la PSI y a niveles operativos inferiores con la validación del Responsable correspondiente.

20. CUMPLIMIENTO DE LOS REQUISITOS MÍNIMOS DE SEGURIDAD.

El SCS, para lograr el cumplimiento del Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad, que recoge los principios básicos y de los requisitos mínimos, ha implementado diversas medidas de seguridad proporcionales a la naturaleza de la información y los servicios a proteger teniendo en cuenta la categoría de los sistemas afectados.

1. Organización e implantación del proceso de seguridad.

La seguridad de los sistemas de información y la protección de datos deberá comprometer a todos los miembros de la organización.

La PSI deberá ser conocida por todas las personas que formen parte de la organización e identificar a los responsables de velar por su cumplimiento: responsable de la información, responsable del servicio, responsable de la seguridad y responsable del sistema.

2. Análisis y gestión de riesgos.

El análisis y la gestión de los riesgos será parte esencial del proceso de seguridad y será una actividad continua y permanentemente actualizada, conforme a los principios de gestión de la seguridad basada en los riesgos y reevaluación periódica (artículos 7 y 10 del Real Decreto 311/2022, de 3 de mayo).

La gestión de los riesgos permitirá el mantenimiento de un entorno controlado, minimizando los riesgos a niveles aceptables. La reducción a estos niveles se realizará mediante una apropiada aplicación de medidas de seguridad, de manera equilibrada y proporcionada a la naturaleza de la información tratada, de los servicios a prestar y de los riesgos a los que estén expuestos.

Esta gestión se realizará por medio del análisis y tratamiento de los riesgos a los que está expuesto el sistema, mediante empleo de alguna metodología reconocida internacionalmente. Las medidas adoptadas para mitigar o suprimir los riesgos deberán estar justificadas y, en todo caso, existirá una proporcionalidad entre ellas y los riesgos.

El proceso de gestión de riesgos, que comprende las fases de categorización de los sistemas, análisis de riesgos y selección de medidas de seguridad a aplicar, que deberán ser proporcionales a los riesgos y estar justificadas, deberá revisarse cada año por parte del Responsable de la Seguridad y personas en quien delegue, y se elevará un informe al COCOSEG.

3. Gestión de personal.

El personal, propio o ajeno, con acceso a los sistemas de información del SCS, estará formado e informado de sus deberes, obligaciones y responsabilidades en materia de seguridad. Tiene la obligación de conocer y cumplir esta PSI y la normativa de seguridad de desarrollo así como la normativa en materia de protección de datos personales.

Su actuación será supervisada para verificar que se siguen los procedimientos establecidos y se aplican las normas y procedimientos operativos de seguridad aprobados en el desempeño de sus cometidos.

4. Profesionalidad.

La seguridad de los sistemas de información estará atendida, revisada y auditada por personal cualificado, dedicado e instruido en todas las fases de su ciclo de vida: planificación, diseño, adquisición, construcción, despliegue, explotación, mantenimiento, gestión de incidencias y desmantelamiento.

Dicho personal deberá cumplir los requisitos de formación y experiencia exigidos por el SCS para el ejercicio de sus funciones.

5. Autorización y control de los accesos.

El SCS ha implementado mecanismos de control de acceso a los sistemas de información, limitándolos a los usuarios, procesos, dispositivos y otros sistemas de información, debidamente autorizados, y exclusivamente a las funciones permitidas.

6. Protección de las instalaciones.

El SCS implementa mecanismos de control de acceso físico, previniendo los accesos físicos no autorizados, así como los daños a la información y a los recursos, mediante perímetros de seguridad, controles físicos y protecciones generales en áreas.

7. Adquisición de productos de seguridad y contratación de servicios de seguridad.

Para la adquisición de productos o contratación de servicios de seguridad el SCS, tendrá en cuenta la utilización de forma proporcionada a la categoría del sistema y el nivel de seguridad determinado, aquellos que tengan certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición.

Para la contratación de servicios de seguridad se atenderá a lo señalado en cuanto a la profesionalidad.

8. Mínimo privilegio.

Los sistemas de información deben diseñarse y configurarse otorgando los mínimos privilegios necesarios para su correcto desempeño proporcionando la funcionalidad imprescindible para que el SCS alcance sus objetivos siendo las funciones de operación, administración y registro, las mínimas necesarias para ello y asegurando que solo son desarrolladas por las personas autorizadas desde recursos asimismo autorizados.

9. Integridad.

La inclusión de cualquier elemento físico o lógico en el catálogo actualizado de activos del sistema, o su modificación, requerirá autorización formal previa.

La evaluación y monitorización permanentes permitirán adecuar el estado de seguridad de los sistemas atendiendo a las deficiencias de configuración, las vulnerabilidades identificadas y las actualizaciones que les afecten, así como la detección temprana de cualquier incidente que tenga lugar sobre los mismos.

10. Incidentes de seguridad, prevención, detección, reacción y recuperación.

El SCS dispondrá de procedimientos de gestión de incidentes de seguridad y de mecanismos de detección, criterios de clasificación, procedimientos de análisis y resolución, así como de los cauces de comunicación a las partes interesadas.

La seguridad del sistema contemplará las acciones relativas a los aspectos de prevención, detección y respuesta, al objeto de minimizar sus vulnerabilidades y lograr que las amenazas sobre el mismo no se materialicen o que, en el caso de hacerlo, no afecten gravemente a la información que maneja o a los servicios que presta.

11. Protección de la información almacenada y en tránsito y continuidad de la actividad.

Se prestará especial atención a la información almacenada o en tránsito a través de los equipos o dispositivos portátiles o móviles, los dispositivos periféricos, los soportes de información y las comunicaciones sobre redes abiertas, que deberán analizarse especialmente para lograr una adecuada protección.

Se aplicarán procedimientos que garanticen la recuperación y conservación a largo plazo de los documentos electrónicos producidos por los sistemas de información, cuando ello sea exigible.

Los sistemas dispondrán de copias de seguridad y se establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones en caso de pérdida de los medios habituales.

12. Existencia de líneas de defensa y prevención ante otros sistemas de información interconectados.

El Servicio Canario de Salud ha implementado una estrategia de protección del sistema de información constituida por múltiples capas de seguridad, constituidas por medidas organizativas, físicas y lógicas, de tal forma que cuando una capa ha sido comprometida permita desarrollar una reacción adecuada frente a los incidentes que no han podido evitarse, reduciendo la probabilidad de que el sistema sea comprometido en su conjunto y minimizar el impacto final sobre el mismo.

Se protegerá el perímetro del sistema de información, especialmente, cuando el sistema se conecte a redes públicas, tal y como se definen en la legislación vigente en materia de telecomunicaciones, reforzándose las tareas de prevención, detección y respuesta a incidentes de seguridad.

En todo caso, se analizarán los riesgos derivados de la interconexión del sistema con otros sistemas y se controlará su punto de unión. Para la adecuada interconexión entre sistemas se estará a lo dispuesto en la normativa correspondiente.

13. Registro de actividad.

El SCS, con el propósito de satisfacer el objeto de esta Política de Seguridad, con plenas garantías del derecho al honor, a la intimidad personal y familiar y a la propia imagen de los afectados, y de acuerdo con la normativa sobre protección de datos personales, de función pública o laboral, y demás disposiciones que resulten de aplicación, registrará las actividades de los usuarios, reteniendo la información estrictamente necesaria para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas, permitiendo identificar en cada momento a la persona que actúa.

14. Infraestructuras y servicios comunes.

Se tendrá en cuenta que la utilización de infraestructuras y servicios comunes de las administraciones públicas, incluidos los compartidos o transversales, facilitará el cumplimiento de la normativa vigente.

15. Vigilancia continua, reevaluación periódica, actualización del sistema y mejora continua del proceso de seguridad.

La vigilancia continua por parte del SCS permitirá la detección de actividades o comportamientos anómalos y su oportuna respuesta.

La evaluación permanente del estado de la seguridad de los activos permitirá medir su evolución, detectando vulnerabilidades e identificando deficiencias de configuración.

Las medidas de seguridad se reevaluarán y actualizarán periódicamente, adecuando su eficacia a la evolución de los riesgos y los sistemas de protección, pudiendo llegar a un replanteamiento de la seguridad, si fuese necesario.

El proceso integral de seguridad implantado deberá ser actualizado y mejorado de forma continua. Para ello, se aplicarán los criterios y métodos reconocidos en la práctica nacional e internacional relativos a la gestión de la seguridad de las tecnologías de la información.

21. PROTECCIÓN DE DATOS DE CARÁCTER PERSONAL.

El SCS, en el tratamiento de los datos personales, cumple con los principios y obligaciones de la normativa vigente, entre otra el Reglamento 679/2016, del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la Protección de las Personas Físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento General de Protección de Datos-RGPD) y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de derechos digitales.

De conformidad con el artículo 3 del ENS, el responsable o encargo del tratamiento, asesorado por el DPD, realizarán un análisis de riesgos conforme al artículo 24 del RGPD y, en los supuestos de su artículo 35, una evaluación de impacto en la protección de datos. En todo caso prevalecerán las medidas a implantar como consecuencia del análisis de riesgos y, en su caso, de la evaluación de impacto en la protección de datos, en caso de resultar agravadas respecto de las previstas en el Real Decreto 311/2022, de 3 de mayo, por el que se regula el ENS.

En desarrollo de los principios de la vigente normativa de protección de datos, entre otros, los de minimización, confidencialidad o proactividad, el SCS ha definido su marco de actuación interno en la Política de Protección de Datos.

En caso de conflicto con la normativa de seguridad prevalecerá la norma que presente un mayor nivel de exigencia respecto a la protección de los datos de carácter personal.

22. FORMACIÓN Y CONCIENCIACIÓN.

El SCS desarrollará actividades orientadas a la concienciación y formación de todo el personal en materia de seguridad de la información y protección de datos personales, así como a la difusión de la PSI y su desarrollo normativo, particularmente dirigidas al personal de nueva incorporación, de modo que garantice que todos conocen, entienden y cumplen las normas y las medidas de protección en materia de seguridad adoptadas, advirtiéndoles de los riesgos que puede suponer el mal uso de los dispositivos y tecnología a su alcance.

Recibirán formación específica las personas con responsabilidad en el uso, operación o administración de sistemas TIC en la medida que la necesiten para realizar su trabajo de forma segura.

23. TERCERAS PARTES.

Cuando se utilicen servicios de terceros o se comunique información a terceros, se les hará partícipes de esta PSI y de las Normas Generales Seguridad que atañen a dichos servicios o información y se establecerán procedimientos de actuación para la reacción ante

incidentes de seguridad. Dicha tercera parte quedará sujeta a las obligaciones establecidas en la citada normativa, pudiendo desarrollar sus propios procedimientos operativos para satisfacerla.

24. REVISIÓN Y APROBACIÓN DE LA PSI.

Esta PSI será efectiva desde su fecha de publicación y hasta que sea reemplazada por una nueva política.

Las propuestas de las revisiones de la PSI serán elaboradas por el Responsable de la Seguridad con el apoyo del Comité de Coordinación y los roles de la PSI que requiera, serán aprobadas por el Comité Coordinación de Seguridad de la Información y Protección de Datos y deberán adoptarse por Resolución de la persona titular de la Dirección del SCS.